

NAME: SANIA SOHAIL

INTERN AT: Petalnex Pvt. Ltd.

INTERNSHIP DOMAIN: AI AUTOMATION

Day 27 — Security Audit & Secret Management

1. Objective

The purpose of this security audit was to review my Week 1–Week 4 n8n automation work and improve the protection of credentials, user data, and webhook endpoints.

2. Security Findings

I reviewed my workflows for common security risks, including hard-coded API keys and passwords, exposed credentials, secrets in documentation or screenshots, secrets committed to GitHub, unsecured webhooks, and unnecessary exposure of sensitive data.

3. Fixes Applied

Credentials are managed using n8n credential management instead of being written directly into workflow logic. Database and API credentials are kept in credential configuration. I also checked project documentation and screenshots to make sure that passwords, API keys, tokens, and other secrets are not exposed.

4. Secured Webhook

I created a secured POST webhook named “secure-intake” and enabled Header Auth authentication. The webhook uses an n8n Header Auth credential so the authentication secret is not written directly into the workflow.

5. Webhook Workflow

The secured workflow follows this path: Secure Webhook → Process Request → Respond OK. The webhook accepts authenticated requests, processes the request, and returns a JSON response with HTTP status 200 for an accepted request.

6. Authentication and Authorization

Authentication checks whether a request is allowed to access the endpoint. Authorization determines what an authenticated user or service is allowed to do. The workflow uses a dedicated credential for webhook authentication and follows the principle of least privilege.

7. PII and Sensitive Data

Sensitive information such as email addresses, passwords, API keys, access tokens, database credentials, and customer information should not be unnecessarily exposed. Secrets should not be placed in screenshots, documentation, or public repositories.

8. Final Security Checklist

- ✓ API keys are not hard-coded in workflow logic.
- ✓ Database passwords are not hard-coded.
- ✓ Credentials are stored using n8n credential management.
- ✓ Secrets are not stored in the README or project documentation.
- ✓ Secrets are not shown in screenshots.
- ✓ Secrets are not committed to GitHub.
- ✓ A Header Auth security check was added to a webhook.
- ✓ The webhook uses POST and requires Header Auth authentication.
- ✓ Sensitive user data is handled carefully.
- ✓ Least-privilege access was considered.

9. Conclusion

The security audit improved the reliability and trustworthiness of my n8n automation work. The main security principle followed is: never hard-code, expose, or publicly share secrets. Store credentials securely and authenticate requests before allowing them to continue.